NEXUS WORK 쉬운 해설 버전 비전공자·심사위원 맞춤형 일상 비유 + 쉬운 어휘

PPT 슬라이드 발표 대본 (어려운 전문용어 풀이판)

어려운 기술 용어를 일상 비유와 직관적인 한국어로 풀어내어 누구나 쉽게 이해할 수 있는 구두 대본

발표자	쉬운 핵심 개념	1부 시연 요약	2부 발표 요약
홍주형 (웹·DB 디비 하드닝 / 코어)	가짜 미끼 함정 & 불변 자물쇠	미끼 건드린 해커 현장 검거	스위치를 꺼도 안 뚫리는 설계

1부. 기능 구현 라이브 테스트 (팀 4인 통합 연계)

⏱ 홍주형 파트: 약 1분 (가짜 미끼 함정 시연)

1부 라이브 시연 | 화면 분할 시연

디코이(허니팟) 미끼 함정: 취약 모드(허용) vs 방어 모드(입구 컷) 실증

⏱ 60~70초

💡 **쉬운 비유로 이해하기:**
• **디코이(허니팟):** 빈 금고 안에 '비밀 장부'라고 써 붙인 **가짜 서류봉투(미끼)**를 둔 것입니다. 정상 직원은 건드릴 이유가 없지만, 도둑(해커)은 반드시 손을 대는 심리를 이용한 함정입니다.
• **취약 모드 vs 방어 모드:** 취약 모드는 도둑 명단에 이름만 적히고 문은 열려 있는 상태, 방어 모드는 문지기가 입구에서 즉시 쫓아내는(403) 상태입니다.

🎙 **쉬운 구두 발표 대본 (이시헌 님에게 바통 터치받은 직후)**

"네, 이어서 웹 애플리케이션 계층의 **'가짜 미끼 함정(디코이) 즉시 차단'** 시연을 보여드리겠습니다.

[1단계: 취약 모드 시연 — 명단엔 오르지만 문은 열려 있는 상태]
먼저 관제 화면 상단 스위치가 **'방어 모드 OFF** 오프 **'** 인 취약 상태에서 진행하겠습니다.
해커가 회사 비밀번호가 적힌 환경설정 파일(/.env 슬래시 닷엔브)을 훔쳐보려고 찔러보는 상황을 터미널에서 실행해 보겠습니다."
(PowerShell 파워셸 **터미널에서 공격 명령어 실행)**

```
curl.exe -s -o NUL -w "%{http_code}`n" "http://192.168.3.10:5070/.env"
```

"터미널을 보시면 **404 Not Found** 사공사 낫 파운드, 즉 **'그런 페이지 없습니다'**라는 평범한 에러가 떴습니다. 해커가 눈치채지 못하도록 겉으로는 시치미를 뚝 뗀 것입니다.
하지만 우측 브라우저의 **차단 IP 관리 화면(**/admin/blocked-ips 어드민 블록트 아이피스**)** 을 보시면, 방금 공격한 해커의 IP 주소가 **'함정을 건드린 위험 IP'**로 즉시 적발되어 등록되었습니다.
(강조) 다만 보시는 것처럼 **취약 모드에서는 위험 IP 명단에만 올랐을 뿐 실제 방어벽이 꺼져 있어서, 해커가 포털 메인 페이지에 그대로 접속**할 수 있습니다.

[2단계: 방어 모드 ON 전환 — 문지기가 입구에서 즉시 쫓아내는 상태]
이제 관제 화면 상단의 **'방어 모드 ON** 온 **'** 스위치를 켜겠습니다. 단 0.1초 만에 시스템 전체의 진짜 방어벽이 가동됩니다.
이 상태에서 방금 미끼를 건드려 적발된 해커의 컴퓨터로 다시 페이지 접속을 시도해 보겠습니다.
보시는 것처럼 **즉시 403 Forbidden** 사공삼 포비든**, 즉 '접근이 전면 거부되었습니다'라는 경고와 함께 입구에서 완벽하게 차단**되어 더 이상 들어갈 수 없습니다!

보안 감사 장부(/admin/audit 어드민 오딧)에도 차단 기록이 투명하게 남았습니다.
클릭 한 번으로 [차단 해제]하여 정상 상태로 복구하는 것까지 보여드렸습니다. 이어서 김태빈 님의 404 스캔 시연으로 넘기겠습니다."

2부. 본인 파트 상세 설명 (어려운 기술을 쉽게 풀어낸 1:1 대본)

⏱ 총 소요 시간: 5~7분 (슬라이드 10장 + 마무리 1장)

PPT Slide 19 | 우하단 20 / 40 | 03. 앱·DB 하드닝 (간지 — 토글로도 꺼지지 않는 권한 방어) | ⏱ 30초

💡 **하드닝(Hardening)이란?**
건물 입구에 경비원을 세우는 것도 중요하지만, **건물 벽 자체에 철판을 덧대고 방문마다 튼튼한 금고 자물쇠를 채워 체질 자체를 단단하게 굳히는 기본 공사**입니다.

🎙 **쉬운 구두 발표 대본 (슬라이드 19번을 띄우며)**

"안녕하십니까! **NEXUS WORK** 넥서스 워크 **보안 프로젝트**에서 **웹 애플리케이션과 데이터베이스의 뼈대를 단단하게 보강하는 '하드닝'**을 총괄한 **홍주형** 입니다.
앞서 팀원들이 외곽 울타리와 감시 카메라 파이프라인을 구축했다면, 저는 해커가 최종적으로 노리는 **내부 금고와 문서함 자체를 쇠창살로 굳히는 작업**을 맡았습니다.
저희 시스템의 가장 큰 자랑은, 관리자가 실수로 방어 스위치를 꺼두더라도 **중요한 인사 정보나 관리자 권한은 결코 뚫리지 않는 '절대 고정 방어선'**을 만들었다는 점입니다. 지금부터 그 구조를 알기 쉽게 설명해 드리겠습니다."

PPT Slide 20 | 우하단 21 / 40 | 01 · 담당 범위 (앱·DB 하드닝 전체 책임 8대 설계) | ⏱ 40초

💡 **8대 설계 알기 쉬운 비유:**
- **AST 쿼리 검사:** 개발자가 엉성하게 문장을 합쳐 SQL 인젝션 구멍을 내지 못하게 하는 **'코딩 자동 맞춤법 검사기'**
- **Argon2id & 열거 방지:** 최고 등급 디지털 금고 & 아이디가 맞든 틀리든 똑같은 문구로 답해 **직원 명단 유출 방지**
- **DB 물리 격리:** 웹 서버가 해킹당하더라도 **급여·기밀 문서는 열람만 되고 절대 수정·삭제를 못 하도록** 물리적 분리

🎙 **쉬운 구두 발표 대본 (슬라이드 20번을 짚으며)**

"21페이지, 제가 시스템 전반에 적용한 **8가지 핵심 안전장치** 입니다.
1. **데이터베이스 쿼리:** 개발자가 실수로 위험하게 코드를 짜지 못하도록, 문법 구조를 돋보기로 자동 검사하는 **'정적 문법 검사기(AST** 에이에스티 **)'**를 강제 적용했습니다.
2. **로그인 보안:** 최신 최고 보안 등급 암호화(Argon2id 아르곤 투 아이디)를 적용했고, 5번 틀리면 15분간 잠급니다. 특히 없는 아이디를 넣어도 '아이디 또는 비번 오류'라고 똑같이 응답해 **우리 회사 직원 명단을 해커가 캐내지 못하게** 막았습니다.
3. **신분증(세션) 보호:** 해커가 악성 스크립트로 로그인 신분증을 훔치지 못하도록 **스크립트 접근을 원천 차단(HttpOnly** 에이치티티피 온리 **)** 했습니다.
4. **기밀 데이터 격리:** 일반 게시판은 글쓰기가 되지만, **급여나 사내 기밀 문서는 웹 서버가 오직 '읽기'만 가능하도록 물리적으로 분리**하여, 설령 서버가 털려도 데이터 변조가 원천 불가능합니다."

PPT Slide 21 우하단 22 / 40

02 · 개념 (왜 데모 스위치와 무관한가 — 디코이 vs 권한 방어 대조)

45초

💡 **IDOR(아이도어)와 불변 룰의 쉬운 비유:**
• **IDOR(안전하지 않은 직접 객체 참조):** 호텔 주소창 끝 번호를 내 방 번호인 22번에서 1번(사장실)으로 슬쩍 바꿨을 때, 문이 열려버리는 취약점입니다.
• **불변 룰:** 호텔 프런트에서 '야간 경비 모드'를 실수로 껐다고 해서 일반 투숙객이 사장실 문을 열 수 있으면 안 되듯이, **스위치와 상관없이 서버 프로그램 뼈대 자체에 자물쇠를 단단히 박아둔 것**입니다.

🎙 **쉬운 구두 발표 대본 (슬라이드 21번 핵심 개념 설명)**

"22페이지는 심사위원분들께서 가장 주목하시는 **'왜 방어 모드 스위치를 꺼도 절대로 뚫리지 않는가'**에 대한 원리입니다.
앞서 1부 시연에서 보셨듯이, 미끼 함정(디코이 IP 차단)은 스위치를 끄면 접속이 허용되고 켜야만 차단되는 **'토글형 방어'** 입니다.

하지만 **제가 구현한 '관리자 권한 통제'와 '타인 정보 열람 차단(IDOR 아이도어)'은 스위치를 끄든 켜든 절대로 뚫리지 않습니다.**
그 이유는, 이 권한 검사 코드들은 '스위치가 켜져 있나?'를 쳐다보는 조건문 자체가 아예 없습니다. 마치 호텔 프런트 스위치가 꺼져 있어도 사원증으로 사장실 문을 열 수 없도록, **서버 백엔드 로직에 영구적인 고정 자물쇠로 박아두었기 때문** 입니다."

PPT Slide 22 우하단 23 / 40

03 · 라이브 검증 (test 계정으로 실제 검증한 결과표)

40초

💡 **결과표 핵심 요약:**
내 인사카드(22번)는 정상 열람(200 OK)되지만, 주소창 번호만 1번으로 바꿔 남의 개인정보를 보려 하거나 관리자 메뉴로 들어가려는 행위는 **스위치를 켜든 끄든 100% 동일하게 차단(403 Forbidden)**됩니다.

🎙 **쉬운 구두 발표 대본 (슬라이드 22번 실측 데이터 제시)**

"23페이지는 일반 사원 계정으로 실제 검증한 실측 성적표입니다.
보시는 것처럼 본인의 인사카드인 22번은 **200 OK** 이백 오케이 로 정상 조회되지만,
- 주소창 번호만 1번으로 조작해 남의 개인정보나 급여를 훔쳐보려는 시도,
- 사내 기밀 문서함 접근,
- 그리고 관리자 전용 메뉴 접근은 **예외 없이 403 Forbidden** 사공삼 포비든 **, 즉 '당신에게는 접근 권한이 없습니다'라며 즉시 튕겨냈습니다.**
방어 모드 스위치를 ON 온 으로 두든 OFF 오프 로 풀든, 결과는 100% 한 치의 오차 없이 완벽히 방어되었습니다."

PPT Slide 23 우하단 24 / 40

04 · 실측 캡처 (실제 화면으로 확인한 차단)

30초

💡 **브라우저 조작 무력화:**
겉포장 화면(HTML)만 가려둔 것이 아니라, **서버 컴퓨터 핵심 로직에서 문을 걸어 잠갔기 때문에** 개발자 도구로 화면을 뜯어고쳐도 절대로 들어갈 수 없습니다.

🎙 **쉬운 구두 발표 대본 (슬라이드 23번 캡처 증적 제시)**

"24페이지는 실제 화면에서 차단된 증거 캡처입니다.
좌측 화면은 주소창 끝 번호만 1번으로 바꿔 타인 인사카드를 보려다 거부당한 화면이고, 우측은 일반 사원이 관리자 화면에 무단 접근하려다 거부당한 화면입니다.
눈속임으로 버튼만 숨긴 게 아니라, **서버 심장부에서 권한을 철저히 검사해 차단** 하기 때문에 브라우저 개발자 도구로 화면을 조작해도 결코 뚫을 수 없습니다."

PPT Slide 24 우하단 25 / 40

05 · 탐지 연동 (Graylog R9 · R10 — 거부 이벤트로 남는 흔적)

40초

💡 **관제 장부 자동 기록:**
도둑이 남의 방문을 따려고 손잡이를 흔드는 순간, **"누가, 몇 시 몇 분에, 어떤 문을 따려다 실패했는지"** 관제실 모니터에 빨간 글씨로 실시간 자동 박제되는 구조입니다.

🎙 **쉬운 구두 발표 대본 (슬라이드 24번 관제 연동 설명)**

"25페이지는 이렇게 차단된 침해 시도가 관제 센터에 어떻게 실시간 보고되는지를 보여줍니다.
누군가 비인가 페이지를 찔러보는 순간, 시스템 내부 감사 장부(/admin/audit **어드민 오딧**)에 **'권한 거부(authz_deny 어스지 디나이)'** 기록이 실시간으로 남습니다.
관리자 페이지를 찔렀으면 **'직급 부족(insufficient_role)'**, 남의 카드를 훔쳐보려 했으면 **'소유 범위 벗어남(out_of_scope)'** 이라는 정확한 사유와 계정명이 찍히며, 이 데이터가 관제 센터(Graylog **그레이로그**)로 날아가 관제 요원이 해커의 이상 징후를 즉각 감시할 수 있습니다."

PPT Slide 25 우하단 26 / 40 **06 · 결재 무결성 (5단계 결재 BOLA 차단 & 지출결의서 서버 재검산)** 50초

💡 **BOLA와 서버 강제 재검산 쉬운 비유:**
• **BOLA(결재 순번 새치기):** 대리 결재도 안 났는데 부장이나 사장이 먼저 도장을 찍으려 하거나, 남의 결재 도장을 가로채서 대신 찍으려는 행위입니다.
• **서버 강제 재계산:** 공격자가 인터넷 창에서 **100만 원짜리 품의 총금액을 슬쩍 '1만 원'으로 바꿔 전송해도, 서버가 부품 수량과 단가를 직접 곱해서 대조**해 튕겨내는 위조 방어벽입니다.

🎙️ **쉬운 구두 발표 대본 (⭐ 가장 인상 깊었던 백엔드 코드)**

"26페이지는 제가 개발하면서 가장 자부심을 느끼는 **'전자결재 위조 방어와 서버 강제 재계산'** 로직입니다.

첫째, **결재 새치기(BOLA 볼라) 원천 차단:** 기안부터 사장님 승인까지 5단계를 무조건 순서대로 거치도록 강제하여, 자기 차례가 아니거나 중간 결재자를 건너뛰면 **'지금 당신 차례가 아닙니다(not_your_turn)'** 라며 거부합니다.
둘째, **금액 위조 방어:** 해커가 브라우저를 조작해 품의 총금액을 100만 원에서 1만 원으로 위조해 결재를 올리더라도, 서버는 사용자가 보낸 합계 금액을 절대 믿지 않습니다.
서버 컴퓨터가 직접 품목별 수량과 단가를 가져와 계산기를 다시 두드려 검산하며, 단 1원이라도 차이가 나면 **'위조 감지(tamper_detected)'** 에러를 내뿜고 위조 시도 자체를 감사 로그에 박제해 버립니다."

PPT Slide 26 우하단 27 / 40 **07 · 코어 개선 (실시간 보안 모드 동기화 버그 수정)** 45초

💡 **실시간 방송(SSE) 동기화 비유:**
유튜브 라이브 스트리밍 채팅처럼, 관제실에서 방어 버튼을 누르는 순간 **새로고침을 누르지 않아도 다른 모든 관제 모니터에 0.1초 만에 상태가 실시간 방송(SSE)**되도록 고친 것입니다.

🎙️ **쉬운 구두 발표 대본 (슬라이드 26번 문제 해결 1)**

"27페이지는 개발 과정에서 끝까지 추적해 잡아낸 **모니터 실시간 동기화 버그 해결** 입니다.
관리자가 방어 스위치를 켜도, 다른 자리에 있는 관제 모니터는 F5 새로고침을 누르기 전까지 예전 상태로 멈춰 있는 심각한 관제 사각지대가 있었습니다. 코드를 까보니 실시간 방송 수신기가 누락되어 있었습니다.

➔ **해결:** 스위치를 전환하는 즉시 서버가 모든 모니터에 이벤트를 실시간 방송(SSE 에스에스이)해 주도록 고쳤고, **0.1초 만에 화면의 배지와 버튼이 깜빡임 없이 즉각 갱신** 되도록 완성했습니다. 3초 자동 확인과 창 복귀 동기화까지 3중 안전장치를 달았습니다."

PPT Slide 27 우하단 28 / 40 **08 · 성능 최적화 (AI 판정 4중 캐스케이드로 15~30초 → 0.5~1.0초)** 50초

💡 **AI 4단 이어달리기 안전망 & 무결함(Zero-Regression):**
• **AI 4단 이어달리기:** 1순위 초고속 번개 AI(0.5초)가 먼저 맡고, 장애 나면 2순위 고성능 AI, 인터넷 끊기면 3순위 사내 로컬 AI, 최악의 순간엔 0.01초 내장 규칙 엔진이 이어받는 무중단 파이프라인입니다.
• **Zero-Regression(제로 리그레션):** 속도를 98%나 빠르게 튜닝했음에도, **기존 251가지 기능 중 단 한 개도 고장 나지 않고 완벽하게 유지**되었음을 뜻합니다.

🎙 **쉬운 구두 발표 대본 (슬라이드 27번 문제 해결 2)**

"28페이지는 AI 에이아이 침해 분석 속도를 획기적으로 개선한 **성능 최적화** 입니다.
기존에는 로컬 컴퓨터 혼자 AI를 돌리다 보니 침해 하나를 분석하는 데 **15초에서 30초** 나 걸렸습니다. 해커는 1초 만에 도망가는데 분석이 늦어져 앞단 방화벽이 타임아웃으로 터지는 병목이 발생했습니다.

➔ **해결:** 클라우드와 로컬을 결합한 **'AI 4단 이어달리기(캐스케이드)'** 체계를 구축했습니다.
평소엔 1순위 초고속 클라우드 AI(Groq 그록)가 **0.5초 만에 초고속으로 판정** 하고, 클라우드 장애 시 2순위 엔비디아 AI, 인터넷이 끊어지면 3순위 사내 독립 AI, 최악의 비상시엔 4순위 내장 규칙 엔진(0.01초)이 바통을 넘겨받습니다.
그 결과 **속도를 98% 단축** 시켰고, 251가지 자동화 기능 테스트를 단 42초 만에 통과하며 **단 한 건의 부작용도 없는 완전 무결함(Zero-Regression 제로 리그레션)** 을 증명했습니다."

PPT Slide 28 우하단 29 / 40 **09 · 다음 계획 (문제 해결과 다음 계획)** 40초

💡 **향후 개선 쉬운 비유:**
• **중앙 인가 엔진(OPA):** 각 방마다 자물쇠 규칙을 따로 코딩하지 않고, **본사 중앙 관제탑에서 야간 출입 통제 규칙을 원격으로 일괄 배포**하는 구조로 고도화합니다.
• **FIDO2 패스키:** 털릴 수 있는 비밀번호 대신 **스마트폰 지문이나 USB 하드웨어 보안키**를 꽂아야만 결재가 승인되는 피싱 불가 2차 인증입니다.

🎙 **쉬운 구두 발표 대본 (슬라이드 28번 향후 계획 제시)**

"29페이지는 개발 중 겪은 문제 해결과 향후 발전 계획입니다.
화면 캡처 스크립트 오류나 윈도우 파일 잠금 문제를 예외 처리로 안정화했고, 모든 동작을 실측 콘솔로 재검증했습니다.

향후 발전 계획:
1. **중앙 출입 정책 관제탑(OPA 오파) 도입:** 현재 코드에 박혀 있는 권한 검사를 중앙 엔진으로 분리하여, 야간 근무 외 출입 통제 같은 동적 정책을 프로그램 재배포 없이 즉각 적용하겠습니다.
2. **지문·하드웨어 보안키(FIDO2 파이도 투 패스키):** 임원 결재나 기밀 문서 열람 시, 피싱이 불가능한 실물 보안키 인증을 강제하여 비밀번호 탈취 위협을 원천 차단하겠습니다."

PPT Slide 39 우하단 40 / 40 **마무리 (4명, 4개 방어선, 하나의 체계) & 예상 Q&A 3선** 1분 30초

🎙 **쉬운 구두 발표 대본 (팀 마무리 총평)**

"마지막 40페이지, 팀 전체 마무리입니다.
외곽 성벽과 감시 카메라가 혹시 뚫리더라도, 제가 구축한 앱과 데이터베이스 뼈대가 최후의 보루로서 **'문서 위조 불가'와 '권한 새치기 불가'**를 철저히 지켜내어, 우리 4조 팀원 모두의 노력이 유기적으로 결합된 완벽한 다중 방어 체계를 완성했습니다.
질문을 받기에 앞서, 심사위원분들께서 가장 궁금해하실 만한 **핵심 질문 3가지**를 알기 쉽게 미리 답변드리겠습니다."

❓ **Q1. 방어 모드 스위치를 끄면 실제 보안이 꺼지나요, 아니면 화면만 바뀌는 데모용 가짜인가요?**

🎙 **쉬운 답변:** "가짜 데모가 아니라, **실제 서버 메모리와 환경변수를 실시간으로 조작해 실제 방어를 해제하는 진짜 물리적 스위치**입니다. 1부 시연에서 보셨듯이 실제로 스위치를 끄면 미끼 함정에 걸려도 접속이 허용되고 비밀번호 연속 실패 잠금도 풀립니다. *하지만 제가 만든 관리자 권한과 개인정보 보호 로직은 이 스위치를 꺼도 결코 꺼지지 않는 '절대 고정 방어벽'*으로 설계해 두었기 때문에 403 차단이 완벽하게 유지됩니다."

❓ **Q2. 결재 총금액을 해커가 100만 원에서 1만 원으로 고쳐서 올리면 서버가 어떻게 알아채나요?**

🎙 **쉬운 답변:** "해커가 인터넷 브라우저를 뜯어고쳐서 100만 원짜리를 1만 원이라고 우기며 서버로 보내더라도, 저희 서버는 사용자가 보낸 총금액 숫자를 아예 무시합니다. **서버 컴퓨터가 직접 품목 리스트를 가져와서 '수량 곱하기 단가'를 자체 계산기로 직접 계산**합니다. 사용자가 보낸 금액과 1원이라도 틀리면 즉시 '위조 감지' 에러를 내며 거래를 거부하고 감사 장부에 증거를 박제합니다."

❓ **Q3. 1순위 초고속 클라우드 AI로 로그를 보낼 때 회사 비밀이 밖으로 새어 나가진 않나요?**

🎙 **쉬운 답변:** "매우 예리한 질문이십니다. 서버 밖으로 로그를 보내기 전에, 주민번호, 비밀번호, 개인 인증키 같은 민감한 글자를 **정규식 필터로 까맣게 먹칠(마스킹)하여 안전하게 익명화**한 뒤 전송합니다. 또한 만약 군부대나 국가 기관처럼 외부 인터넷이 완전히 끊긴 폐쇄망 환경이라면, 설정 한 줄로 외부 클라우드를 건너뛰고 **사내 독립 AI나 0.01초 내장 규칙 엔진만으로 안전하게 작동**하도록 설계되어 있습니다."

(답변 후) *"이상으로 발표를 마치겠습니다. 추가 질문이 있으시면 편하게 말씀해 주시기 바랍니다. 감사합니다!"*